

Poonawalla Fincorp Limited

Business Continuity Management Policy

Effective Date: 25.10.2024

Approval Date: 25.10.2024

Version No.: 8.0

Approved By: Board of Directors

Policy Owner: Information Security
team

This document is Internal in nature and supersedes any existing Policy on Business Continuity Management policy in the Company and should be read in conjunction with the most recent policies and procedures documented.

BUSINESS CONTINUITY MANGEMENT POLICY

Document review and approval

Document Control

Document Name	Business Continuity Management Policy
Document Version	8.0
Frequency of review	Yearly
Effective Date	25.10.2024
Reviewed by	Chief Information Security Officer
Approved by	Board of Directors
Policy Owner	Information Security Team

Version Control

Date	Version	Change Description (in brief)
		Name of the Company changed to Poonawalla Fincorp Limited w.e.f 22.07.2021
27.10.2021	4.0	To align with the regulatory requirements
21.10.2022	5.0	• Update the in-scope departments in PFL • Update the composition of BCP Advisory Group
20.10.2023	6.0	• Minor Document Update
18.01.2024	7.0	To align with the regulatory requirements
25.10.2024	8.0	Updation of BCP locations and composition of BCP Advisory group.
17.10.2025	8.0	Annual Review- No changes suggested

Table of Contents

Introduction.....	5
1. Introduction.....	5
2. Purpose.....	5
3. BCMS Objectives	5
4. Scope and Applicability	6
5. Exclusion.....	7
6 BCMS Roles and Responsibilities	11
7 Related Policies.....	14
8 Abbreviations.....	14
9 Definitions	15
10 Appendix.....	15
1 Annex 1: BCM Structure.....	15

Introduction

1. Introduction

Poonawalla Fincorp Limited (PFL) is committed to ensuring a continuous and reliable delivery of key products and services to customers in the event of a significant business disruption, while maintaining confidence levels of its clients and shareholders, and satisfy relevant compliance and regulatory requirements, by way of implementing and sustaining an organization-wide Business Continuity Management System (BCMS).

2. Purpose

The BCMS Policy establishes the principles necessary to ensure emergency response, resumption, recovery and restoration of PFL's processes and business activities during a disaster.

This policy defines the overall Business Continuity practice at PFL and contains individual and functional responsibilities required to achieve continuity of business in case of a critical business disruption of key services and minimize the resultant financial and non-financial impact.

The purpose of establishing a BCMS Policy at PFL is to:

- Enable continuity of critical business processes/services in the event of an emergency such as major failures of information systems or unavailability of the primary facility of business,
- Establish BCMS objectives in conjunction to PFL's business objectives,
- Establish scope of BCMS implementation,
- Establish an approach to BCMS,
- Establish BCMS governance framework,
- Ensure that all Business Continuity activities are performed as per the Business Impact Analysis,
- Establish a suitable mechanism to ensure compliance to this policy.
- Ensure maintenance/management of the BCMS

3. BCMS Objectives

PFL's BCMS is designed to recover its business processes/services identified as critical. Contingency measures should be identified to safeguard its enablers (**people, technical infrastructure, facilities and vital records**) in the event of a disruption of services that affects PFL's customers and stakeholders. PFL

should develop, periodically update, and regularly test business continuity plans, which are designed to achieve the following BCMS objectives:

- a) From a business perspective:
 - 1) Supporting its strategic objectives.
 - 2) Creating a competitive advantage.
 - 3) Protecting and enhancing its reputation and credibility.
 - 4) Contributing to organizational resilience.
- b) From a financial perspective:
 - 1) Reducing legal and financial exposure.
 - 2) Reducing direct and indirect costs of disruptions.
- c) From the perspective of interested parties:
 - 1) Protecting life, property, and the environment.
 - 2) Considering the expectations of interested parties.
 - 3) Providing confidence in the organization's ability to succeed.
- d) From an internal processes' perspective:
 - 1) Improving its capability to remain effective during disruptions.
 - 2) Demonstrating proactive control of risks effectively and efficiently.
 - 3) Addressing operational vulnerabilities.

4. Scope and Applicability

The scope of BCMS at PFL covers:

- Departments functioning from the PFL Office
- And cloud applications and infrastructure managed by PFL.

BCM for SaaS based applications is managed by SaaS vendor or as per contractual agreement. The BCMS scope encompasses the following departments and location within PFL:

Category	Description
Office Location	Head Office, and Branch Offices
In scope departments PFL	• Customer Service & Cross Sell • Credit • Recovery/ Collections • POC (Pre-Owned Car) • Operations • Treasury • Collection • Sales • Taxation • Unsecured Business Loan

Category	Description
	• Human Resource • Digital Marketing • Accounts • Secured Loans LAP
Common Departments	• Treasury • Finance - Accounts, taxation, planning • Admin, HR • IT • Corporate communication • Legal & Compliance • Customer service • Risk • HO Operations • Branch Operations

5. Exclusion

This business continuity plan excludes outages from cloud service providers where PFL infrastructures are hosted. (e.g. AWS, OCI, and Azure etc.).

6. Business Continuity Management System

5.1 Policy Statement

PFL is committed to ensuring a continuous and reliable delivery of key services to its customers in the event of a significant business disruption, while upholding confidence levels of its customers and shareholders, by developing, implementing and maintaining an effective Business Continuity Management System ("BCMS").

5.2 Business Continuity Plan (BCP)

- PFL shall develop Business Continuity Plans (BCPs) for critical processes with recovery within RPO and RTO of the disaster (as per the approved BIA results), to ensure adequate recovery at the time of disaster/crisis.
- BCPs shall be documented based on identified RTO and RPO values calculated during the BIA.
- BCPs shall take into account process requirements including all enablers (people, site, technology and vital records) and identified interdependencies.
- BCPs shall be reviewed and updated by respective BCMS Champions at least once a year or in case of a major change in organization structure, people or process.

5.3 Policy Governance

5.3.1. BCP Advisory Group

The functioning of the BCP shall be monitored by the BCP Advisory Group and BCP test report shall be placed before the Board by way of periodic reports.

Roles and Responsibility of BCP Advisory Group

- Reviewing and recommending strategies to implement the Business Continuity & Disaster recovery Policy.
- Approving Business Continuity & DR Policy documents and ensuring that the management has put an effective strategic planning process in place.
- Ascertaining that management has implemented processes and practices that ensure the business continuity, resumption, and recovery of critical business applications.

5.3.2. Composition of BCP advisory group

- Chief Risk Officer (CRO)
- Chief Technology Officer (CTO)
- Chief Information Officer (CIO)
- Chief Information Security Officer (CISO)
- Application Head
- Head of ITs
- IT Governance
- The BCP advisory group will meet at least once a year. The CTO / CIO shall be responsible for formulation, review, and monitoring of the BCP to ensure continued effectiveness.
- The BCP advisory group will ensure that at minimum, the necessary administrative support functions in the recovery effort, such as human resources, insurance, legal and security are in place. They should also ensure that all levels of staff are cognizant of the importance of BCPs and the business recovery objectives.

5.4 Business Impact Analysis & Risk Assessment

- PFL shall conduct IT Business Impact Analysis (BIA) for all business processes to identify their criticality and impact of unavailability on the organization in the event of a disaster.
- BIAs will identify time critical processes, services and functions, interdependencies and establish specific Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for the Processes, IT systems and applications under such circumstances. Process criticality shall be determined using a weighted impact assessment of loss or process interruption.
- Risks/threats that could cause an adverse impact to PFLs' infrastructure or information assets resulting in a disaster shall be identified in a Risk Assessment and mitigated through implementation

of appropriate controls (as approved by the BCP Advisory Group) within agreed timelines.

- Risk Assessment shall be carried out by BCMS Champions based on the history of such events and their current applicability and shall be approved by respective Department Heads.
- BIAs shall be carried out by BCMS Champions from respective departments, as specified in the BIA & RA procedure, on an annual basis or in the case of a major changes to the department/organization.
- Results from BIAs and RAs shall be reviewed by concerned Department Heads/risk owners.

5.5 Crisis Management

- PFL will establish a business continuity plan to effectively manage a crisis scenario including identification of crisis, emergency response, invocation of Business Continuity Plans and Return to Normal.

5.6 BCM Recovery Strategies

- PFL shall develop appropriate BCM Strategies (BCP Plan) in line with the results from the BIA that take into consideration recovery requirements for processes critical for recovery.
- BCP for SaaS based application shall be managed by SaaS vendor or as per contractual agreement.
- Appropriate recovery strategies shall be chosen based on the nature and intensity of damage resulting from the disaster.
- These strategies shall be updated in case of a major change at an organizational level.

5.7 BCP Awareness

PFL management is determined to embed Business Continuity into its routine operations and management processes. This includes communicating this policy to all employees and the importance of meeting BCMS objective and will ensure that BCMS Champions, Department Heads and BCMS Manager are aware of how they contribute to the achievement of the Business Continuity Objectives.

5.8 Testing & Exercising

- PFL shall conduct BCMS exercises to ensure alignment of its BCPs with BCMS objectives.
- BCMS exercises shall be conducted based on scope approved by BCP Advisory Group; a reporting mechanism shall be established to highlight the results of these exercises to senior management,
- Periodicity of DR drills for critical information systems shall be at least on a half yearly basis.
- BCMS Champions shall maintain, and update as required, a call tree for their respective departments, in coordination with HR.
- A test schedule shall be defined indicating how and when each element of the plan is to be tested and approved by the BCMS Advisory Group.

- Formal testing documents (test plans, objectives, scenarios, procedures and results) shall be developed and maintained by the BCMS Manager for audit purposes.
- A post-test analysis report shall be prepared (including testing performance against testing goals, and mitigating measures for identified risks) and presented to the BCP Advisory Group.
- Testing frequency: Test the BCP either annually or when significant IT or business changes take place to determine if the entity could be recovered to an acceptable level of business within the timeframe stated in the contingency plan.

5.9 Monitoring & Review

- In order to monitor the effectiveness of BCMS at PFL, the following shall be conducted:
 - i. Management reviews (Annually at least once)
 - ii. Performance Evaluation of BCMS objectives (Annually)

The BCMS Manager shall document and track all non-conformities and respective corrective actions with respect to BCMS plan.

- The BCP Advisory Group shall monitor and review the effectiveness and efficiency of the BCMS, review the appropriateness of the Business Continuity Policy, objectives and scope, and determine and authorize actions for remediation and improvement. To ensure this, following activities shall be undertaken on a periodic basis:
 - i. Monitor and Review: It is a self-assessment process for the maintenance of BCMS. Self-assessment process may get triggered as per the scheduled program, or as a result of changes in the organization. Consists of Management Review and Third-Party Audits to monitor the established BCMS.

5.10 Maintaining & Improving

PFL management is determined to maintain and improve the effectiveness of the BCMS by taking preventive and corrective actions, as determined by the BCMS monitoring and reviews. Non-Conformity/Corrective Action shall be documented using the NCCA (Non-Conformity and Corrective Action) form, and improvement actions shall be planned, if any of the non-conformities are

- Received after third party audits,
- Learning's from any incident,
- Post BCMS testing & exercises planned as part of the program,
- Post self-assessment reviews,
- Received after internal and external audits, and
- Post management review of BCMS

6 BCMS Roles and Responsibilities

In accordance with the BCMS requirements outlined by International Standard ISO 22301, PFL shall define an effective BCMS structure comprising of nominated or appointed persons with appropriate seniority and authority to be accountable to this policy and related framework implementation. The BCMS Implementation will be governed by the BCP Advisory Group.

(Please refer to Annex 1: BCMS Management Structure, for details regarding the BCMS structure at Poonawalla Fincorp Limited).

6.1 Roles and responsibilities of BCP Advisory Group

- Ensuring safety and security of all PFL employees,
- Ensuring the BCMS policy, framework and Business Continuity objectives are established and compatible with the strategic direction of the organization,
- Discuss key risks related to Business Continuity including legal and regulatory compliance risks covering ISO 22301.
- Directing the recovery of critical processes and services, in case of a crisis/disaster event,
- Taking tactical decisions by providing immediate recovery response to the incident, restoration to normal,
- Creating a planning structure that shall enable PFL to follow a Business Continuity Plan (“BCP”) to ensure continuity of the business operations after a major disruption occurs,
- Monitoring and reviewing BCMS implementation at regular intervals through BCP Advisory Group meetings,
- Providing assistance to BCMS implementation team when required, and
- Resolving conflicts and disputes, reconciling differences of opinion and approach.

6.2 Roles and responsibilities of BCMS Manager (CISO/Information Security)

The BCMS Manager (CISO/Information Security) is responsible for:

- **Business as usual/pre-disaster**
 - i. Developing, implementing, and managing a risk assessment practice to identify, assess and address potential business continuity/emergency situations and their respective controls,
 - ii. Working closely with all departments in identifying their business continuity needs,
 - iii. Working with BCMS Champions to define business continuity strategies, plans & procedures for all areas specific to business continuity, and obtaining approvals on them from respective Department Heads,
 - iv. Working with departments to define department level business continuity procedures such as

emergency manuals,

- v. Working closely with senior management to obtain approvals on budgets for provisions of business continuity infrastructure, such as offsite facilities or additional IT resources,
- vi. Acting as a mediator between business departments and the IT department to ensure alignment of business needs with available IT facilities,
- vii. Ensuring that BIAs are conducted periodically or triggered after a change in the organization/department,
- viii. Ensuring that risk assessments are conducted at least annually,
- ix. Initiating annual management review of all strategies, plans & procedures, and ensuring that they are maintained up to date and that they reflect the current business needs,
- x. Overseeing & supervising periodic testing of the business continuity plan & maintaining updated copies of all documents,
- xi. Ensuring that all the business continuity management documents reflect the current needs of PFL and are regularly updated and reviewed regularly to ensure effectiveness of controls at all times.
- xii. Liaising and coordinating with all business continuity management teams including the BCP Advisory Group, and other relevant business and IT recovery teams, during maintenance, improvement, and operation of BCMS at PFL,
- xiii. Coordinating with internal and external auditors for audit of PFL's BCMS plan ensuring any audit observations are addressed and closed in a time bound manner.
- xiv. Staying informed about latest developments in business continuity management field including technology, business & management practices.

- **During a disaster**

- i. Acting as a single point of contact between BCP Advisory Group and all other teams during crisis operations,
- ii. Acting as a single point of contact for all Department Heads on operational aspects of their respective business continuity plans during a crisis operation,
- iii. Ensuring that recovery & restore operations are proceeding in an organized & timely manner, and
- iv. Overseeing, and monitoring the overall recovery & restore operations during a crisis situation and regularly updating the BCP Advisory Group on the status of crisis operations.

- **Post- disaster**

- i. Updating the BCP Advisory Group regarding the damage and identifying the mitigation steps.
- ii. Coordinating with respective BCMS Champions to ensure Root Cause Analysis is performed

- post disaster, and
- iii. Maintaining a corrective action tracker to ensure that experiences from disruptions help improve PFL's BCMS program.
- iv. Updating the damage assessment form

6.3 Roles and responsibilities of BCMS Champions

BCMS Champions will include senior resources from each of the departments within the BCMS. The primary responsibility of the BCMS Champions is managing on-going Business Continuity operations as well as activities during an emergency. They will play a critical role in development, testing and the continuous maintenance of the BCMS. The responsibilities of the BCMS Champions include:

- Complete Business Impact Analysis and Risk Assessments for their respective departments,
- Update relevant BCMS documents to reflect and changes to their department (personnel, process, etc.),
- Train other team members in performing BCMS activities as an ongoing process,
- Identify the stages at the time of the emergency and guide the teams on recovery steps.
- Initialize and de-activate BCMS activities and be part of recovery process,
- Periodically check and validate Business Continuity requirements,
- Coordinate all the activities within the department during an emergency,
- Take up emergency issues/resolution to the BCP Advisory Group, and
- Interface with other departments to ensure smooth BCMS operations.

6.4 Roles and responsibilities of Department Heads

Department Heads are responsible for ensuring that:

- Employees within their department are familiar with this Policy and are aware of their roles and responsibilities in this respect,
- Review and approval of BCMS activities during BIA, RA, BCM Strategy & Plan, and Testing,
- Ensure adequate BCMS Awareness is present within the department,
- Decision on emergency declaration for the department in the absence of BCP Advisory Group,
- Prioritization of activities during recovery during disaster recovery, and
- Issuing communication to employees and stakeholders within respective departments.

6.5 Roles and responsibilities of IT Disaster Recovery Team

IT Disaster Recovery Team shall be responsible for recovering the IT systems during emergencies, taking critical decisions in the event of a crisis – purported or genuine. All critical decisions shall be

consensus driven while taking into consideration the size and complexity of the various operations. The final decision will be made by PFL CTO/CIO . These decisions shall include but are not limited to:

- Assess the IT continuity activation level,
- Declaration of an IT emergency, and
- Activate the IT DR plan.

Responsibilities include:

- Managing and monitoring the overall IT Disaster Recovery Process,
- Immediately notifying of IT emergency declaration to team members,
- Coordinating with third party service providers, IT vendors and support personnel, and
- Providing continuous support services to business users at the disaster recovery location.

7 Related Policies

This Policy should be read together with other relevant policies and procedures in place within PFL

8 Abbreviations

Terms	Definitions
BCMS	Business Continuity Management System
BCP	Business Continuity Plan
BIA	Business Impact Analysis
ITDR	Information Technology Disaster Recovery
RA	Risk Assessment
RPO	Recovery Point Objective
RTO	Recovery Time Objective
NCCA	Non-Conformity and Corrective Action

9 Definitions

“Business continuity”: The ability of an organization to maintain critical business processes during and after, a severe business disruption has occurred.

“Business continuity management”: A holistic management process that identifies potential threats to an organization and the impacts to business operations those threats, if realized, might cause, and which provides a framework for building organizational resilience with the capability of an effective response that safeguards the interests of its key stakeholders, reputation, brand and value-creating activities.

“Business continuity management system”: BCMS part of the overall management system that establishes, implements, operates, monitors, reviews, maintains and improves business continuity.

“Business impact analysis”: Process of analysing activities and the effect that a business disruption might have upon them.

“Invocation”: act of declaring that an organization’s business continuity arrangements need to be put into effect in order to continue delivery of key products or services.

“Non-conformity”: Non-fulfilment of a requirement.

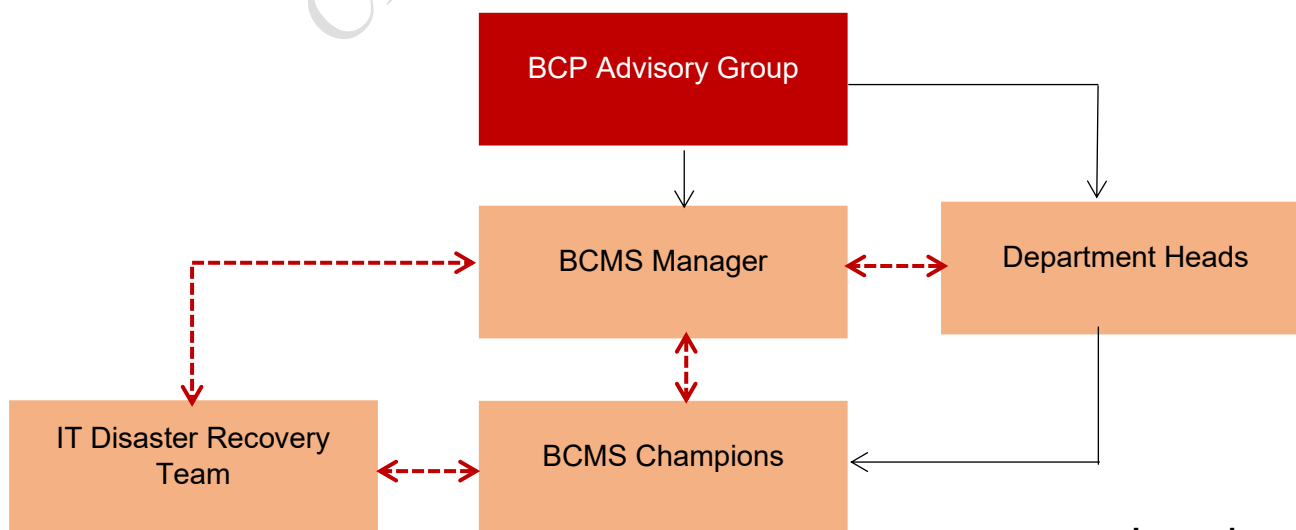
“RPO”: The point to which information used by an activity must be restored to enable the activity to operate on resumption.

“RTO”: Period of time following an incident within which

- a) product or service must be resumed, or
- b) activity must be resumed, or
- c) resources must be recovered

10 Appendix

1 Annex 1: BCM Structure



Legend:

Liaise with:

Directs to: